



EXCELLIUM

Your first call when it comes to IT and Security

Onboard Security guys into DevOps

Why do you move to **DevOps**?

- Time to market.
- Align business objectives/needs with software delivery delay and content.
- Increase quality of produced software and reduce software development cost.
- Increase software productivity.

Why add the **Sec** in DevOps?

- Take back control on security maturity of systems created.
- Decrease software delivery, production release, marketing publishing postpone due to security issues.
- Clearly define and track the expected level of security expected by the software.
- Detect and fix security flaws more quickly during requirement, design and implementation stages of your DevOps pipeline.
- Provide proof to auditor and client about control on the security of the software produced.
- Decrease your dependency for security assessment services from security providers in other case than external "*Compliance*" assessment requirement (*the famous annual "penetration test" performed in December just before Christmas holidays*).

What if I told you...



Your SEC guys are amazing

Why leverage **your Sec guys**?

- They know your:
 - Core business.
 - Sensitive assets.
 - IT and Business processes.
 - Dev and Ops teams.
 - History/culture....and your weaknesses...
- They know where security validations should be added in DevOps pipeline.
- Allow them to be part of the DevOps pipeline **represents a amazing source of motivation and job evolution for them...**

Which changes for **Sec** guys job?

- DevOps increase **software delivery speed** and change the **working team mindset** so you must **adapt your work and mindset** to the new model.
- Move posture from “**Group policy X don't allow to do that...**” to “**You should/can do it using this way...**”
- Move from **auditor posture** to **team member posture** by providing practical recommendation and advices on team technical problematics.
- Imagine and propose solution/work around instead of bring blocking situation.
- Become the “**Security Champion**” of the company and the security buddy of the Dev and Ops teams in the DevOps pipeline.

Challenges for the **Sec** guy?

- Go **back to the ground** in order to add security in DevOps pipeline, take vacation from “**security by policy**” approach.
- Gain technical knowledge/understanding **about Dev and Ops work/mindset/technologies** to include security check on projects in a smooth and practical ways.
- Gain **offensive point of view** to help team to spot security issues.
- Identify and gain technical knowledge about security tools that can help Dev and Ops **to continuously evaluate the security** of the thing that they build.
- Evaluate, adapt, tune and use theses tools in close collaboration with Dev and Ops teams. Share knowledge, success **and failure** about theses tools.

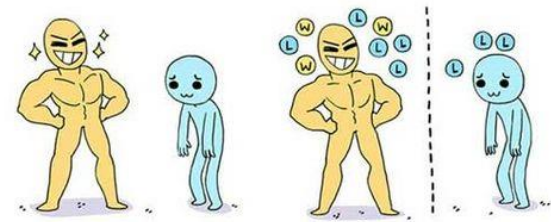
So I can join DevOps teams...



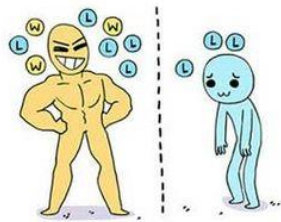
Tell me what can I do

Pushing left Security in pipeline

- Add security validations points along the whole DevOps pipeline.
- Use tools that allow team to gain knowledge about the security issues meet : **“Learn by failure !”**
- Security guy is **not a anymore an slowdown point** but a guy that help for security topics, questions or actions.
- Security guy can say:
 - *“I don’t know but I will do research on this topic!”*
 - *“Try this, this is an prototype to fix your issue...”*



PEOPLE THINK THERE ARE WINNERS AND LOSERS.



BUT THE WINNERS ALSO LOSE.



THEY LOSE MORE THAN THE LOSERS.



THEY'RE SECRETLY JUST SUPERLOSERS.



DON'T BE A LOSER

BE A SUPERLOSER.

Pushing left Security in pipeline

Design phase

- Help to identify abuse cases for the software's features.
- Define associate countermeasure to setup/implements of each abuse cases.

Pushing left Security in pipeline

Implementation phase

- Setup static code analysis tools (SAST), audit profile and tune them.
- Integrate the audit in the Continuous Integration Process of the software.
- Help DevOps team to understand audit reports and integrate issues into bug trackers in a practical way.
- Help DevOps team to access issues from their IDE.
- Help DevOps team to understand the issues found and provide them the appropriate remediation.

Pushing left Security in pipeline

Implementation phase

- Same thing about the 3rd party dependencies & container security.
- Same thing about the dynamic analysis (DAST) of deployed software (ex: web or mobile app scan).
- Help team to add more advanced security test like authentication & authorization tests...
- Be able to perform an internal audit of the software (code review, vulnerability assessment, hardening...).

Pushing left Security in pipeline

Provision & deployment phase

- Enable team to embed Web Application Firewall configuration into software and provision the WAF configuration on-the-fly to validate rules efficiency it on test environment during integration processes.
- Enable team to test/audit the security of their provisioned environment in a automated way (ex: using script like the one from the CIS about Docker/Container) and get a direct usable feedback to apply remediation.

Pushing left Security in pipeline

Provision & deployment phase

- Enable team to use provision recipes that include by default security best practices for the target system (ex: Ansible hardening recipes).
- Tune these recipes according to the security maturity level needed of the system and the DevOps team technical constraints: **Business requirements pilot the Security, never the reverse !**
- Be able to perform an internal audit of the infrastructure configuration underneath (configuration review, network assessment, architecture review hardening...).

I still do manual boring tasks...



Why leverage automation?

- Allow close integration of security validations into DevOps pipeline.
- Allow a first step of integration of security validations with quick feedback to teams prior to include advanced assessment.
- Allow the creation of dashboards to track evolution of the security maturity of the system across the time including the maintenance phase of the system.
- Free up time for added value tasks like manual code review, vulnerability assessment (our famous beloved WAVA and MAVVA from Excellium 😊)...

Focus on SAST



Focus on Container Security



aqua

Container Security
Made Simple

Keypoints to keep in your bag...

- Include your internal Security people in your DevOps strategy.
- DevSecOps is for your Sec, Dev and Ops people:
 - A job evolution opportunity and so an HR advantage.
 - A source of motivation, knowledge and team building.
- DevSecOps is for you (CISO) a way to:
 - Increase the trust of your client in your business and your systems.
 - Proof your security maturity level to external auditor.

Thank you – Any questions?



<https://www.excellium-services.com>